

CIS RAM and the VERIS Community Database

**Understanding and Updating the VCDB for CIS RAM
for CIS Controls v8.1**

November 2025

Acknowledgments

The original content of CIS RAM was developed by HALOCK® Security Labs. It is based on their extensive experience helping clients and legal authorities resolve cybersecurity and “due care” issues. Recognizing the universal need for a vendor-neutral, open, industry-wide approach to these issues, HALOCK Security Labs and the Center for Internet Security, Inc. (CIS®) collaborated so that this process would be openly available to the entire cybersecurity community. This generous contribution of intellectual property (and the extensive work to generalize and tailor it to the CIS Critical Security Controls® (CIS Controls®) has been donated to CIS and is now available and maintained as a CIS community-supported best practice.

As with all CIS work, we welcome your feedback, and we welcome volunteers who wish to participate in the evolution of this and other CIS products.

CIS gratefully acknowledges the contributions provided by HALOCK Security Labs and the DoCRA Council in developing CIS RAM and the CIS RAM Workbook.

Editor

Chris Cronin, Partner, HALOCK Security Labs

Contributors

Phillippe Langlois, Verizon

Sarah Day, CIS

Valecia Stocchetti, CIS

Robin Regnier, CIS

This work is licensed under a Creative Commons Attribution-Non Commercial-No Derivatives 4.0 International Public License (the link can be found at <https://creativecommons.org/licenses/by-nc-nd/4.0/legalcode>).

To further clarify the Creative Commons license related to the CIS Controls® content, you are authorized to copy and redistribute the content as a framework for use by you, within your organization and outside of your organization for non-commercial purposes only, provided that (i) appropriate credit is given to CIS, and (ii) a link to the license is provided. Additionally, if you remix, transform, or build upon the CIS Controls, you may not distribute the modified materials. Users of the CIS Controls framework are also required to refer to (<http://www.cisecurity.org/controls/>) when referring to the CIS Controls in order to ensure that users are employing the most up-to-date guidance. Commercial use of the CIS Controls is subject to the prior approval of the Center for Internet Security, Inc. (CIS®).

Contents

Introduction	1
Who Is This Model For?	2
Why Expectancy?	3
How Expectancy is Estimated	4
Maturity Scores	5
VCBD Index	6
Why a Semi-Quantitative Method?	7
How the Expectancy Matrix Is Built	7
Updating the VCDB Data	8
Detailed Update Instructions	9
Summary of VCDB Changes	10

Introduction

The objective of the CIS Risk Assessment Method (CIS RAM) for the VERIS Community Database (VCDB) is to demonstrate to CIS RAM users how their “expectancy” scores are calculated, and to help them refine Expectancy Scores for their enterprise.

CIS RAM is unique among cybersecurity risk assessment methods. While CIS RAM evaluates risks using some form of likelihoods and impacts as all risk analysis methods do, it stands out for three important reasons:

- 1 It uses the three principles of Duty of Care Risk Analysis (DoCRA) to determine when risks and safeguards are “reasonable” and “acceptable” as regulations require.
- 2 It automates likelihood estimates (in CIS RAM we call these “expectancy” estimates) using crowd-sourced data and maturity scores.
- 3 In the Implementation Group 3 (IG3) version, CIS RAM maps to the CIS Community Defense Model (CDM) v2.0, allowing the enterprise to understand how well their CIS Safeguards would defend against the top five attack types (e.g., ransomware, malware).

This CIS RAM module will help users understand why CIS opted to use the VCDB as its data source, how the VCDB data is transformed so it is useful in a risk assessment, and how Expectancy Scores are automatically estimated.

This module will also indicate where CIS RAM users may find opportunities in the VCDB to further refine the data, so it is more suitable to their industry.

We hope the CIS RAM user community finds this module to be helpful. And as always, we encourage ideas and contributions from the community for future developments of the assessment method and its modules.

Who is this Module for?

CIS RAM and the VERIS Community Database is for CIS RAM users who wish to understand any of the following items:

- How CIS RAM automates estimation of “expectancy” scores
- Why CIS RAM uses the word “expectancy” rather than “likelihood”
- How CIS RAM users can update the VCDB data themselves
- How CIS RAM users can further refine the VCDB data to better reflect risks in their industry

The first two topics can be readily used by CIS RAM users either for their own benefit, or to explain the risk assessment method to others. The second two topics will require some level of comfort and agility with large datasets. They describe processes that will require them to use Microsoft Excel, even in a rudimentary way.

The authors of this module will assume that all readers will be familiar with the content of the v2.1 or v2.2 CIS RAM Core document and/or the RAM modules for IG1, IG2, or IG3.

The CIS RAM and VERIS Community Database module is intended for explanatory purposes only. Because of this, it is not accompanied by workbooks that are specific to the module, as is the case for CIS RAM for IG1, IG2, and IG3. Rather, it will refer to sections of those workbooks and use them to illustrate some of this module’s topics.

Why Expectancy?

CIS RAM 2.2 uses the term “expectancy” instead of the terms “likelihood” or “probability” that readers may be more familiar with. The term “expectancy” implies that we know a cybersecurity incident will occur, we are just determining the most likely way it will happen in our enterprise. CIS RAM v2.2 does this by pairing two pieces of information – how commonly a threat causes incidents in the world and how prepared an asset’s safeguards are to prevent those threats. The more prepared an asset’s safeguards are to prevent common threats, the less the enterprise should expect those threats to successfully attack the asset.

We can put this more simply: The more prepared we are for more common threats, the less we expect those threats to be a problem for us.

But why create an alternative to the terms “probability” and “likelihood” that most other assessment methods use? After all, CIS RAM 1.0 used “likelihood” as well.

Firstly, the terms “probability” and “likelihood” imply that we are estimating the timing of the next occurrence of an incident. The CIS RAM team is not confident that one generally applicable method will estimate that occurrence well for each enterprise.

Rather, we turned to the crowdsourced data in the VERIS Community Database (VCDB), a project led by Verizon’s Data Breach Investigations Report team. The VCDB provides the public with thousands of records that detail how publicly reported incidents occurred. The database includes information about the victim, the threat actor, the industry of the victim, and what assets, techniques, and impacts were involved. It’s a very deep and useful dataset. A security incident is defined in VCDB as “any incident/event/occurrence/issue (or whatever) that compromises (or negatively affects) a security attribute (Confidentiality, Integrity, or Availability) of an information asset in any form.”

The data cannot easily be used to determine the probability that any of those threats could occur in an enterprise unless the enterprise had capable statisticians to shape the data for them. That skillset is out of reach for most enterprises.

So, CIS developed a simple model to match VCDB’s data about the commonality of threats to the maturity of Safeguards in the CIS Controls that would prevent those threats. This model could help risk assessors determine which of their Safeguards were more or less prepared for threats of varying degrees of commonality.

The result of such analysis would not indicate that the probability or likelihood of an incident was higher or lower. It would indicate that when an incident does occur, we would expect that some Safeguards would be more or less likely involved in permitting the incident to occur.

Again, the more prepared we are for more common threats, the less we expect those threats to be a problem for us. Hence, “expectancy.”

The CIS RAM team does not take a position on the viability, accuracy, or appropriateness of qualitative or quantitative risk assessment methods. We simply offer a simple and rational model that we believe a large portion of the public can benefit from.

We hope that this document helps further the development of the VCDB as a model for cybersecurity risk estimations.

The figure below illustrates how expectancy is derived by comparing the commonality of threats to the maturity of controls that prevent those threats.

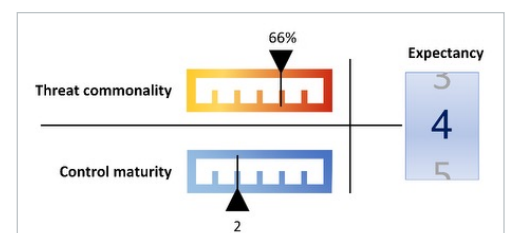


Figure 1. Comparative Illustration

How Expectancy is Estimated

As the illustration above implies, there is a simple way to associate Safeguard Maturity Scores with the commonality of threats. The matrix is shown below.

Figure 2. Expectancy Matrix

Maturity	VCDB Index	Expectancy
5	1	1
5	2	1
5	3	1
5	4	2
5	5	2
4	1	1
4	2	2
4	3	2
4	4	3
4	5	3
3	1	1
3	2	2
3	3	3
3	4	4
3	5	5
2	1	3
2	2	3
2	3	4
2	4	4
2	5	5
1	1	4
1	2	4
1	3	5
1	4	5
1	5	5

First, let's understand what each of these columns means. The Maturity Score indicates the degree that we can rely upon the Safeguard to function as intended. We will discuss how Maturity Scores are selected in a moment. The VCDB Index indicates the commonality that an Asset Class appears in the VCDB as a target of an attack. In other words, threats that target users appear in about 50% of incidents in the VCDB, and applications appear in about 14% of incidents, so the VCDB Index for users will be higher than the VCDB Index for applications. We will explore the VCDB Index in more detail as well.

As the reader can see on the Expectancy Matrix, when a risk assessor states that a Safeguard's Maturity is a '4' and that the Asset Class that the Safeguard protects has a VCDB Index of '2', the Risk Register derives an Expectancy Score of '2'. This means that the current use of this Safeguard that protects this Asset Class would be among the least expected vectors of the eventual incident.

The risk assessor would also find that a Safeguard with a Maturity score of '2' that protects an asset class with a VCDB Index of '5' would be among the most commonly expected vectors for the eventual incident.

Before we go much further, we should look more deeply at Maturity scores and the VCDB Indexes.

Maturity Scores

CIS RAM is interested in the maturity of Safeguards, meaning the degree to which we can rely on a Safeguard being effective when it is needed. Maturity assessments commonly use the CMMI model¹ which implies the formality of how controls and processes are managed. Because CIS RAM intends to derive Expectancy Scores (in part) from Maturity Scores, its Maturity Model describes degrees of reliability of a Safeguard. CIS RAM's Maturity Model is shown below.

Maturity Scores	Definition
1	Safeguard is not implemented or is inconsistently implemented.
2	Safeguard is implemented fully on some assets or partially on all assets.
3	Safeguard is implemented on all assets.
4	Safeguard is tested and inconsistencies are corrected.
5	Safeguard has mechanisms that ensure consistent implementation over time.

Presumably, a risk assessor would be comfortable saying that a Safeguard that is tested and its inconsistencies are corrected would be more reliable than a Safeguard that is implemented everywhere, but not tested. Such a Safeguard would be less reliable than one that was consistently implemented over time (so testing it would reveal that it is consistently operated).

This is not to say that we know that controls are undefeatable, or that we know that all threats can be stopped given our control set. But the maturity model helps us rationally say why we believe that a Safeguard that is designed to prevent or detect known threats is or is not reliably functioning.

¹ CMMI – The Capability Maturity Model Integration that is administered by the CMMI Institute.

VCDB Index

The VCDB Index was developed by CIS as an efficient way to rank assets by their commonality as vectors of attack in the VCDB. While the commonality of assets as attack vectors can be expressed in terms of percentages (for example, 14% of incidents involved attacking applications in the VCDB), an Expectancy Matrix that associated each percentage integer (1% through 100%) with each Maturity Score would be 500 rows long (or 5,000 rows long if we express percentages not as integers, but to the tenth decimal). The length of the table has no practical effect on the risk assessor, but that level of detail also has no benefit, and suggests a degree of specificity or accuracy that retroactive data cannot support.

Rather, the VCDB Index indicates whether assets are more or less common to each other as a vector of attack. This is sufficient for determining whether a Safeguard that protects an Asset Class is expected as a cause for the eventual incident.

Because of this, risk assessors should find that “quintiles” (five evenly distributed percentile ranges) of commonality are sufficient for deriving expectancy.² The table below demonstrates this concept.

Figure 3. VCDB Index Table

VCDB Index	Percentile Range
1	> 0%; <= 20%
2	> 20%; <= 40%
3	> 40%; <= 60%
4	> 60%; <= 80%
5	> 80%; <= 100%

So, when users are a threat vector in 50% of reported cases, user threats would be given a VCDB Index of ‘3’ because 50% is between 40% and 60%.

Collaboration Spotlight

“We are pleased to see how the CIS RAM team is using the VERIS Community Database data to help risk assessors estimate the likelihood of security incidents. This is a great example of why we release this data to the public.

The data in the VCDB is very rich with raw data about the causes, consequences, methods, and assets involved in thousands of cybersecurity incidents. We want this to help risk analysts find many kinds of patterns to help them think about the commonality of anything that might be relevant to their cybersecurity question. If you want to know what techniques are most used in certain industries, you can find that out. If you’re interested in spotting trends in techniques over time, the data is there.

CIS RAM is using the data to ask a very simple question that should be helpful; how commonly asset classes are exploited, and what controls should I focus on if commonality of attacks is an important metric for our enterprise.

So, we’re pleased to see CIS find such a practical use for the VCDB, and we encourage the CIS community to find more novel ways to put this data to work.”

Philippe Langlois
Senior Principal – Threat Intel, Verizon Business Group

² Quoted from “the DoCRA Standard” - <https://www.docra.org>

Why a Semi-Quantitative Method?

CIS RAM's use of quintiles is known in the risk management community as "linear ordinals," meaning, an ordered ranking of things. Ordinals are different from quantitative ranges used to express percentages of probability (0% to 100%, for example). Risk analysts debate about the appropriateness of each mode of estimation, and the CIS RAM team is aware of common shortcomings in the use of ordinals. Excellent work in this debate has been presented by experts such as Douglas Hubbard, Anthony Cox, and Julian Talbot.

While analyzing this debate goes beyond the scope of this module, it is worthwhile to note for risk experts that CIS RAM's use of ordinals avoids or minimizes many of the shortcomings associated with using ordinal scales. Because CIS RAM automates Expectancy Scores using information gained by the VCDB and the enterprise, human bias and inconsistency are avoided. And because the intent of Expectancy Scores is to rank rather than calculate risks, range compression, ambiguity, and quantification errors are not applicable to CIS RAM's risk analysis.

Given enough interest from the CIS RAM community, a quantitative application of the risk assessment method may yet be developed (<https://workbench.cisecurity.org/communities/76>).

How the Expectancy Matrix Is Built

The VCDB includes thousands of records of publicly reported security incidents and approximately 2,500 characteristics about those incidents. Those characteristics are impressively varied, and distinguish factors relevant to an incident, such as the countries that a victim or attacker were in, the monetary currencies involved in incidents, the attack methods used, and the asset types that were involved in the attack.

Of these factors, those that align most with the CIS Controls and Safeguards are what VCDB calls "asset varieties." Example varieties can be categorized as: servers, network, user devices, public terminals, media, and people, among others.

Updating the VCDB Data

This brief document describes how to update the VERIS Community Database (VCDB) data in a CIS RAM workbook. By updating the VCDB data, an enterprise's risk assessment will be based on the most current threat data provided by the VCDB project.

CIS RAM helps enterprises evaluate their cybersecurity risk by estimating the impacts and expectancy of threats. CIS RAM's Expectancy Score is derived by pairing the commonality of certain threats to the maturity of controls that would prevent or otherwise hinder those threats.

Updating the VCDB data is a simple process. This document provides a table that is identical to the VCDB Index table provided in the CIS RAM workbook (in the "Lookup Tables" tab), but for the fact that its data is current.

VCDB Index		Used to populate "VCDB Index"		
Incident Count	10262		As of	3/14/2024
Asset Class	Sum of Threat Count / Industry	Percentage	Index	
Devices	7628	74%	4	
Software	2549	25%	2	
Data	2357	23%	2	
Users	2263	22%	2	
Network	174	2%	1	
Documentation	2357	23%	2	

Update Column

Automatic

Automatic

Detailed Update Instructions

Enterprises that use CIS RAM 2.1 reference either CIS Controls v7.1 or CIS Controls v8.0 as their control set. CIS Controls v7.1 and v8.0 associate their Safeguards to asset classes the same way. Updating the VCDB index for CIS RAM 2.1 workbooks will affect both 7.1 and 8.0 risk registers in the same way. To update the VCDB for CIS RAM 2.1 workbooks, follow the instructions below. Version 2.2 that uses CIS Controls v8.1 is already updated.

1 Users should save a copy of their CIS RAM workbook before updating the data so any accidents can be easily undone by using the backed-up copy.

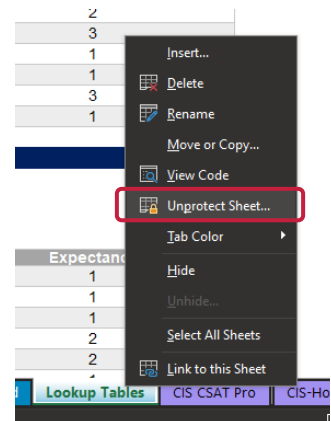
2 To update the table, the user must first make sure the workbook is not protected, which prevents users from editing protected columns.

a The user should click on and display the “Lookup Tables” tab in the CIS RAM workbook.

b Then select the “Review” menu item on the Excel workbook menu.

c If there is a ribbon button named “Unprotect Sheet” then users should click that button, so it displays “Protect Sheet.” The user should now be able to update the VCDB Index table.

d If the ribbon button appears as “Protect Sheet” then the worksheet is already permitting the user to update the data in the VCDB Index table.



3 The user can now update the data within the VCDB Index table.

a We recommend that the user only change the number values in the “Sum of Threat Count” column. That includes the “Incident Count” value above the column title. The “Percentage” and “Index” columns are automatically calculated by comparing the “Sum of Threat Count” values to the “Incident Count” value, so their functions should remain intact.

b If the user updates all the values in the VCDB Index table, rather than preserving the functions, they will need to either re-instate the functions in the “Percentage” and “Index” columns or continue to copy and paste all values provided in subsequent updates.

After completing these steps, the values in the “Risk Score” column will be updated. We recommend you review these scores, and especially whether “Risk Level” values indicate a need to improve the maturity of controls (or a reduction in impacts), or “Reasonable and Acceptable.”

Summary of VCDB Changes

CIS RAM uses the VCDB to model threats because it is the most comprehensive, publicly shared security incident database available. The VCDB team updates the database multiple times per year.

CIS RAM users may notice that the data has not changed remarkably since the previous edition. This is mostly because these data are aggregations of many years of data and adding new records simply adds to pre-established trends. If users wish to see data that is associated with specific industries or timespans, they may do so by working with the VCDB data directly at <http://veriscommunity.net>.

Working with the database to discover aggregations or correlations is beyond the scope of this document. However, a forthcoming CIS RAM module (in draft) will provide instructions for updating the VCDB Index directly from the VCDB data that may provide some guidance for further exploration and shaping of this important dataset.

While the “Sum of Threat Count” and “Incident Count” data have all increased, the only Index values that have changed are associated with Data and Enterprise asset classes.

The CIS RAM team has updated its method for counting Data asset class associated events by counting the number of VCDB records that demonstrate verified confidentiality impacts. The Enterprise asset class “Sum of Threat Count” and “Index” values always reflect the highest values in their columns. This is because the VCDB does not have an “Enterprise” data type associated with attacks. The CIS RAM team reasoned that the Enterprise asset class values should reflect the worst case of any other asset class, given that if something happened to an asset class, it happened to the enterprise as well.

The Center for Internet Security, Inc. (CIS®) makes the connected world a safer place for people, businesses, and governments through our core competencies of collaboration and innovation. We are a community-driven nonprofit, responsible for the CIS Critical Security Controls® and CIS Benchmarks®, globally recognized best practices for securing IT systems and data. We lead a global community of IT professionals to continuously refine these standards to proactively safeguard against emerging threats. Our CIS Hardened Images® provide secure, on-demand, scalable computing environments in the cloud. CIS is home to the Multi-State Information Sharing and Analysis Center® (MS-ISAC®), the trusted resource for cyber threat prevention, protection, response, and recovery for U.S. State, Local, Tribal, and Territorial (SLTT) government entities. To learn more, visit CISecurity.org or follow us on X: [@CISecurity](https://twitter.com/CISecurity).

 cisecurity.org

 email@cisecurity.org

 518-266-3460

 [Center for Internet Security](https://www.linkedin.com/company/center-for-internet-security)

 [@CISecurity](https://twitter.com/CISecurity)

 [TheCISecurity](https://www.youtube.com/TheCISecurity)

 [cisecurity](https://www.instagram.com/cisecurity)

